

****File No.**** EXP202100660

****RESOLUTION OF SANCTIONING PROCEDURE****

From the procedure instructed by the Spanish Agency for Data Protection and based on the following

****BACKGROUND****

****FIRST:**** Between July 7 and July 9, 2021, six complaints were received by the Spanish Agency for Data Protection. These complaints come from individuals, including one from the CONSUMERS AND USERS ASSOCIATION IN ACTION OF MADRID FACUA, and are directed against the DEPARTMENT OF HEALTH OF THE COMMUNITY OF MADRID, with NIF S7800001E. The reasons for the complaints are as follows:

The CONSUMERS AND USERS ASSOCIATION IN ACTION OF MADRID FACUA, echoing information that has appeared in the media, reports that the portal enabled by the Community of Madrid to obtain the COVID Digital Certificate, launched on June 7, allowed any user to access personal data of another citizen. Specifically, by entering random DNI numbers or NIE numbers, one could access personal data of the holders of those identity documents. Therefore, it requests that all necessary actions be initiated so that the Community of Madrid does not incur in similar events again. In another complaint, an individual indicates that, "associated with the web service used to request an appointment for COVID-19 vaccination, there is a service that, without any authentication, reveals data by simply providing valid DNI numbers. If the following URL replaces the DNI "12345678A" with the valid DNI of a resident in the Community of Madrid, it returns results in JSON format indicating data such as: - Surnames - Name - NIF - Date of birth - Contact phone number(s) provided to the Community of Madrid - Social Security number - CIPA. The URL is:

[https://portalciudadanoccd\[.\]sanidadmadrid\[.\]org/ohgreenpass/citizen_mpi/fhir/Patient/?identifier=NNE SP%7C12345678A&_format=json](https://portalciudadanoccd[.]sanidadmadrid[.]org/ohgreenpass/citizen_mpi/fhir/Patient/?identifier=NNE SP%7C12345678A&_format=json)

This link leads to the website of the Department of Health that allows the issuance of the COVID Digital Certificate.

In one complaint, it is noted that on July 7, 2021, due to a computer problem, their data was exposed in the health sector. They used the self-appointment service of the Community of Madrid and on July 6 received the first dose (Pfizer) of the COVID vaccine at the Doce de Octubre hospital. They request that their data (all) remain protected.

Along with the complaint, they provide a screenshot of an appointment confirmation in their name, a screenshot of an SMS confirming the appointment, and a vaccination report. It is not deduced, either from the complaint or from the documentation provided, what data has been exposed or in what manner.

In another complaint, it is noted that "there is a public URL from the Department of Health that allows access to my personal data by DNI or phone (mine or anyone else's). This includes name, surname, date of birth, phone, address, coordinates of the address, names of my children, my wife, her date of birth, her phone...

https://portalciudadanoccd.sanidadmadrid.org/ohgreenpass/citizen_mpi/fhir/Patient/?identifier=NNESP%7C12345678A&_format=json

https://portalciudadanoccd.sanidadmadrid.org/ohgreenpass/citizen_mpi/fhir/Patient/?telecom=6666666666&_format=json

I request its removal, and possibly the obligation for the CAM to inform all affected individuals, in case this is a data breach that requires it."

In others, they echo news published in the press or on television about these events, such as the news from "el diario" with the headline "A failure in the Madrid Health website exposes the data of the king, Pedro Sánchez, or Aznar,"

https://www.eldiario.es/tecnologia/fallo-web-sanidad-madrid-deja-descubierto-datos-rey-miles-personas_1_8114359.html, also expressing their concern about the security breaches that have occurred in recent weeks in the servers of the Department of Health of the Community, which are openly exposing very sensitive personal data of all Madrilenians (DNI, address, phone numbers,...) and highly protected data related to health (vaccination data, notes from health professionals,...), requesting the Spanish

Agency for Data Protection to investigate them.

****SECOND:**** On July 9, 2021, the GENERAL DIRECTORATE OF PUBLIC HEALTH of the DEPARTMENT OF HEALTH OF THE COMMUNITY OF MADRID with NIF S7800001E, presented, through its Data Protection Delegate Committee, a notification of a security breach indicating the following:

Date of breach detection: 07/07/2021 at 17:42.

Date of breach initiation: 07/07/2021.

Breach resolved.

Data processor: INDRA SOLUCIONES TECNOLOGICAS DE LA INFORMACIÓN SLU., with NIF B88018098 (hereinafter INDRA)

(...)

At that moment, they do not know the number of affected individuals, and the profile consists of vaccinated persons against COVID who have the digital certificate.

The affected individuals will be informed through the press or the web.

****THIRD:**** As a consequence of the notification of the aforementioned security breach, on July 19, 2021, the Director orders the General Subdirectorate of Data Inspection to assess the need to carry out the appropriate investigations.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

3/18

previous in order to determine a possible violation of data protection regulations.

FOURTH: In accordance with Article 65.4 of Organic Law 3/2018, of December 5, on Personal Data Protection and Guarantee of Digital Rights (hereinafter LOPDGDD), these complaints were forwarded to the DEPARTMENT, so that it could analyze them and inform this Agency within one month of the actions taken to comply with the requirements set forth in the data protection regulations.

The forwarding, which was carried out in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), was recorded on August 31, 2021, as evidenced by the acknowledgment of receipt in the file.

On September 21, 2021, this Agency received a response letter from the DPD Committee of the entity responsible for the processing, requesting that, in accordance with Article 57 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations, the procedure related to the actions of forwarding and admission (EXP202100624) be consolidated with the investigation procedure (EXP202100660), due to the coincidence of the facts on which they are based, having received both requests for information from this Agency within the framework of the two files, both concerning the security breach that occurred on the citizen portal for obtaining the EU Digital COVID Certificate.

FIFTH: On September 22, 2021, in accordance with Article 65 of the LOPDGDD, the complaint filed by the complainants was admitted for processing.

SIXTH: The General Subdirectorate for Data Inspection proceeded to carry out preliminary investigation actions to clarify the facts in question, by virtue of the functions assigned to control authorities in Article 57.1 and the powers granted in Article 58.1 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and in accordance with the provisions of Title VII, Chapter I, Section Two, of the LOPDGDD, being aware of the following points:

INVESTIGATED ENTITIES

During the present actions, the following entities have been investigated:

DEPARTMENT OF HEALTH of the Community of Madrid with NIF S7800001E, located at C/ MELCHOR FERNÁNDEZ ALMAGRO, Nº 1 - 28029 MADRID (MADRID)

DIRECTORATE GENERAL OF PUBLIC HEALTH of the then Vice-Ministry of Public Health and Covid-19 Plan and currently Vice-Ministry of Health Care and Public Health of the Department of Health of the Community of Madrid, with NIF S7800001E.

Some of the news published regarding this case are:

C/ Jorge Juan, 6
www.aepd.es
28001 – Madrid
sedeagpd.gob.es
4/18

[https://www.lespanol.com/espana/madrid/20210707/brecha-seguridad-desvela-madrilenos-rey-sanc-
hez-casado/594692060_0.html](https://www.lespanol.com/espana/madrid/20210707/brecha-seguridad-desvela-madrilenos-rey-sanc-
hez-casado/594692060_0.html)

[https://www.lespanol.com/espana/20210712/madrid-sigue-sin-obtener-certificado-covid-semana/595
941729_0.html](https://www.lespanol.com/espana/20210712/madrid-sigue-sin-obtener-certificado-covid-semana/595
941729_0.html)

[https://www.eldiario.es/tecnologia/fallo-web-sanidad-madrid-deja-descubierto-datos-rey-miles-persona
s_1_8114359.html](https://www.eldiario.es/tecnologia/fallo-web-sanidad-madrid-deja-descubierto-datos-rey-miles-persona
s_1_8114359.html)

[https://www.telemadrid.es/programas/telenoticias-2/brecha-seguridad-datos-privados-madrid-0-23571
64308--20210707083051.html](https://www.telemadrid.es/programas/telenoticias-2/brecha-seguridad-datos-privados-madrid-0-23571
64308--20210707083051.html)

In the news article from El Español, dated July 7, 2021, it is mentioned that “The portal of the Community of Madrid for obtaining the digital Covid certificate allowed any user to access personal data of thousands of citizens due to a security flaw.” “The error allowed the entry of the ID number of any person, including that of King Felipe VI, Pedro Sánchez, or Pablo Casado, and obtain their personal data, such as address or phone numbers.”

In the same medium, on July 14, 2021, another article is published stating that as of that date, the website in question remains inoperative. They indicate that “Official sources state that 'security filters are being finalized after the last system update that was made last Wednesday and after the unauthorized accesses that occurred that afternoon. It will be operational again shortly.'”

In the news from El Diario, dated 07/07/2021, it is quoted that “The Community of Madrid shuts down the COVID certificate portal, where an error revealed the name, phone number, and address of any citizen by entering their ID number in the URL.” “The Community of Madrid has acknowledged the existence of the breach and blocked access to the COVID certificate portal during the afternoon of that Wednesday. Sources from the Health Department explained to elDiario.es that ‘the incident was caused by the upload of an update that passed the testing protocols and that in the process of implementation generated a breach.’” “This breach, the same sources assure, ‘was resolved within hours after being detected by the quality services.’ However, elDiario.es is aware that the Community of Madrid was warned by cybersecurity experts about the dangerous situation that its COVID certificate system was causing. Sector sources had informed elDiario.es of the presence of the flaw while the Community shut down the entire system as a security measure.” The news includes a screenshot that appears to be in JSON format (a specific data exchange format that uses readable text and facilitates data analysis with certain tools) showing the name and surname of the King of Spain.

In the news from Telemadrid, it is mentioned that “data could be accessed at least until the afternoon of this Wednesday, July 7.” This news includes screenshots of the supposedly accessible data, also in the aforementioned JSON format, showing the following types of data: name and surname, mobile phone numbers, dates of birth, vaccine object (SARS-COV-2), vaccine brand, and arm where it was administered. Other fields show the texts “Greater vulnerability” “Risk group for COVID-19 due to...” Almost all data is crossed out to prevent full visibility and identification of individuals. In this news, they report that to access the data, a proxy program is needed, some of which are free and easily downloadable via the internet. They indicate that thus, simply by entering a random ID number, one could obtain a lot of information about any citizen residing in Madrid, such as name and surname, phone number, social security number, or their addresses, and that an internal identifier is also recognizable, which is exposed and allows one to obtain where and when they were vaccinated, in which arm, and the name of the healthcare professional who administered it.

Information and documentation have been requested from the respondent, and from the response received, the following is inferred:

Regarding the chronology of the events. Actions taken to minimize adverse effects and measures adopted for final resolution

Date of breach detection: Exact 07/07/2021 at 17:42.

Date of breach initiation: 07/07/2021.

Estimated/exact resolution date: 07/07/2021, at 18:32

(...)

Regarding the causes that made the breach possible

(...)

Regarding the affected data

(...)

Possible consequences for the affected individuals.

(...)

Regarding notification to the affected individuals, the representatives of the respondent have stated the following:

(...)

Regarding the data processing assignment

(...)

Regarding the Data Controller and the signing of the service contract with INDRA

(...)

SEVENTH: On July 15, 2022, the Director of the Spanish Agency for Data Protection agreed to initiate sanctioning proceedings against the DEPARTMENT OF

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

6/18

HEALTH, GENERAL DIRECTORATE OF PUBLIC HEALTH (hereinafter the COUNCIL), in accordance with the provisions of Articles 63 and 64 of Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), for the alleged infringement of Article 5.1.f) of the GDPR and Article 32 of the GDPR, classified respectively in Article 83.4 of the GDPR and Article 83.5 of the GDPR.

EIGHTH: Notified of the aforementioned initiation agreement in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (hereinafter, LPACAP), the COUNCIL submitted a written statement of allegations in which, in summary, it states that:

First. - It should be taken into account that the Ministry of Health of the Community of Madrid currently has a high number of personal data processing activities (more than 500 declared processing activities) that cover more than 6 million inhabitants, among which special category data, such as health data, are processed through more than 700 information systems used by the various units providing health services to the citizens of the Community of Madrid.

As can be observed, the essential service provided by the Ministry of Health of the Community of Madrid involves complex management that encompasses several responsible parties, and it should be noted that the events that occurred reflect an infinitesimal percentage in relation to all the operations carried out by the CSCM on a daily basis.

Additionally, as reflected in the information already provided, at the time the incident occurred, it is estimated that around 4 million citizens met these requirements.

And that indeed, the total information of the aforementioned 4 million citizens was not accessed, since the number of illegitimate access attempts received during the breach was 12,862 requests for access to demographic data.

Thus, considering the millions of Covid certificates issued in the Community, only 3 attempts to access data related to the vaccine have been confirmed during the period of impact. Additionally, considering that, as we indicated, to access a citizen's information, the DNI number used had to match the DNI of one of the citizens of the Community of Madrid who was at that moment in the database of the system, which is a very unlikely fact.

Second. - On the other hand, it should also be noted that at the time the described events occurred, we were at the most critical points of the pandemic, in which the vaccination process had just begun, and there was a need to reach and provide the necessary information to citizens as quickly as possible.

This state of health emergency necessitated the rapid development of a large number of new tools to provide the best service to citizens and to overcome the state of pandemic caused by COVID-19 as soon as possible.

Third. - Cyberattacks have become increasingly sophisticated, as technology evolves constantly, and cybercriminals seek new ways and methods to penetrate systems, develop more complex and novel malware, etc.

In light of the above, measures have been established for the continuous improvement of crisis and cyber-incident management, focused on the prevention, detection, and response to security incidents. Specifically, the following measures have been implemented to reinforce security:

(...)

For the reasons stated above, it requests that the procedure initiated be archived, given that these are events that occurred under exceptional conditions of health emergency, where the health of the entire population was especially prioritized, and measures have been adopted to prevent them from happening again.

NINTH: On February 13, 2023, a proposal for resolution was made, in which it is proposed that the Director impose on the MINISTRY OF HEALTH OF THE COMMUNITY OF MADRID, GENERAL DIRECTORATE OF PUBLIC HEALTH, with NIF S7800001E:

- for an infringement of Article 5.1.f) of the GDPR, classified in Article 83.5 of the GDPR, a warning sanction.

- for an infringement of Article 32 of the GDPR, classified in Article 83.4 of the GDPR, a warning sanction.

This proposal for resolution, which was notified to the COUNCIL in accordance with the rules established in Law 39/2015, of October 1, on the Common Administrative Procedure of Public Administrations (LPACAP), was received on February 14, 2023, as evidenced by the acknowledgment of receipt in the file.

There is no record of the submission of allegations to the proposal for resolution.

From the actions taken in the present procedure and the documentation in the file, the following has been established:

PROVEN FACTS

FIRST: On 07/06/2021, the COUNCIL activated a web system for citizens to obtain the Covid Digital Certificate.

SECOND: It is evidenced that due to a failure in this system, illegitimate access to personal data (including health data) was allowed by entering DNI numbers, due to an error in the user validation procedure.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

8/18

LEGAL GROUNDS

I

Jurisdiction

In accordance with the powers granted to each supervisory authority by Article 58.2 of Regulation (EU) 2016/679 (General Data Protection Regulation, hereinafter GDPR), and as established in Articles 47, 48.1, 64.2, and 68.1 of Organic Law 3/2018, of December 5, on the Protection of Personal Data and the Guarantee of Digital Rights (hereinafter, LOPDGDD), the Director of the Spanish Agency for Data Protection is competent to initiate and resolve this procedure.

Furthermore, Article 63.2 of the LOPDGDD states: "The procedures processed by the Spanish Agency for Data Protection shall be governed by the provisions of Regulation (EU) 2016/679, by this organic

law, by the regulatory provisions issued for its development, and, in so far as they do not contradict them, subsidiarily by the general rules on administrative procedures."

II

Preliminary Issues

In the present case, in accordance with Article 4.1 of the GDPR, there is evidence of the processing of personal data, given that the CONSEJERÍA carries out, among other processes, the collection, registration, organization, structuring, storage, use, and access of the following personal data of individuals, such as: name, identification number, contact details, health data, etc.

The CONSEJERÍA performs this activity in its capacity as the data controller, as it is the entity that determines the purposes and means of such activity, by virtue of Article 4.7 of the GDPR.

Article 4, paragraph 12 of the GDPR broadly defines "personal data security breaches" (hereinafter security breach) as "all breaches of security that result in the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or unauthorized communication or access to such data."

In this case, there is a personal data security breach under the circumstances mentioned above, categorized as a confidentiality breach due to unauthorized access by third parties to personal data resulting from an error in the authentication verification for access to the citizen portal related to the EU Digital COVID Certificate, which allowed such access.

It should be noted that the identification of a security breach does not imply the direct imposition of a sanction by this Agency, as it is necessary to analyze the diligence of the controllers and processors and the security measures applied.

Among the principles of processing provided for in Article 5 of the GDPR, the integrity and confidentiality of personal data are guaranteed in paragraph 1.f) of Article 5 of the GDPR. In turn, the security of personal data is regulated in Articles 32, 33, and 34 of the GDPR, which govern the security of processing, the notification of a personal data security breach to the supervisory authority, and the communication to the data subject, respectively.

III

Claims Made

In response to the claims made by the CONSEJERÍA regarding the Initiation Agreement, the following is noted:

First.- The CONSEJERÍA argues that it should be taken into account that it currently has a high number of personal data processing activities (more than 500), covering over 6 million inhabitants, among which special category data, such as health data, are processed through more than 700 information systems used, and that the incidents that occurred reflect an infinitesimal percentage in relation to all the operations carried out by the CONSEJERÍA on a daily basis, (...).

In this regard, it should be noted that such considerations should not be admitted as mitigating factors or circumstances that diminish the severity of the facts; rather, the opposite is true, as precisely because of the high number of processing activities it carries out and the fact that it affects health data, the CONSEJERÍA is obliged to act with the special diligence that must be required of an organization of this nature, which performs numerous personal data processing activities on a massive scale, including special categories of data.

It is worth recalling the Judgment of the National Court of October 17, 2007 (rec. 63/2006), which regarding entities whose activity involves the continuous processing of customer data, states: "...the Supreme Court has understood that there is negligence whenever a legal duty of care is disregarded, that is, when the infringer does not behave with the required diligence. And in assessing the degree of diligence, the professionalism or lack thereof of the subject must be particularly weighed, and there is no doubt that, in the case now examined, when the activity of the appellant involves constant and abundant handling of personal data, it must be insisted on rigor and exquisite care to comply with the legal provisions in this regard."

Second.- The CONSEJERÍA claims that at the time of the events it was at the most critical points of the pandemic and that, given the state of health emergency, it was necessary to develop a large number of new tools with great speed.

C/ Jorge Juan, 6

In light of this, in addition to what was indicated in the previous section regarding the special diligence required of the CONSEJERÍA for the processing of personal data it conducts, it should be noted that both Article 5.1.f of the GDPR and Article 32 of the same legal text emphasize the necessity for the data controller to adopt appropriate technical and organizational measures to effectively apply the principles of data protection and ensure a level of security adequate to the risk, without the circumstance of urgency claimed due to a health emergency being accepted as an exemption. Therefore, it is not possible to appreciate a state of necessity in the present case that justifies the deployment of an application in a defective manner or with errors, which allows unauthorized access to personal data—among them, health data—of a large number of citizens, without having previously conducted the necessary checks to determine its proper functioning, especially compliance with all obligations imposed by the GDPR and other applicable regulations, and whose hasty use may cause a greater harm than that which is intended to be avoided.

Third. – The CONSEJERÍA alleges that cyberattacks have become increasingly sophisticated, with cybercriminals seeking new ways and methods to penetrate systems, develop more complex and novel malware, etc., and that for this reason they have established the measures indicated in their written allegations to reinforce security.

In this regard, it should be noted that the vulnerability detected and exploited by third parties to access personal data illegitimately was not so much due to a sophisticated attack, but rather to negligence (...), and that the CONSEJERÍA justifies this by arguing that it was due to human error and as a consequence of extreme urgency and necessity.

However, this Agency positively values the adoption of new measures that result in greater security concerning the processing of personal data and that help to prevent, in the future, incidents like the one that is the subject of the present procedure.

For all the above reasons, the allegations put forward are dismissed.

IV

Article 5.1.f) of the GDPR

Article 5.1.f) “Principles relating to processing” of the GDPR states:

“1. Personal data shall be:

(...)

f) processed in a manner that ensures appropriate security of the personal data, including protection against unauthorized or unlawful processing and against accidental loss, destruction or damage, by applying appropriate technical or organizational measures (‘integrity and confidentiality’).”

C/ Jorge Juan, 6

The principle of data security requires the application of appropriate technical or organizational measures that ensure the security of personal data and prevent its alteration, loss, processing, or unauthorized or unlawful access. In this regard, security measures are key to guaranteeing the fundamental right to data protection. The existence of the fundamental right to data protection is not possible if confidentiality, integrity, and availability of the data are not guaranteed.

Thus, the security and confidentiality of personal data are considered essential to prevent individuals from suffering negative effects. Therefore, personal data must be processed in a manner that ensures adequate security and confidentiality, especially to prevent unauthorized access or use of such data and the equipment or system used in the processing.

Ultimately, it is the data controller who has the obligation to integrate the necessary guarantees in the processing, with the aim of, under the principle of proactive responsibility, complying with and being able to demonstrate compliance, while respecting the fundamental right to data protection.

In the present case, the principle of confidentiality has been violated as it has been established that unauthorized third parties accessed personal data of citizens in the Web application of the DEPARTMENT for obtaining the Covid Digital Certificate, due to an error in the user authentication process. Access was gained to data such as name and surname, ID number, date of birth, contact phone number(s), health insurance number, and data related to the administration of the Covid vaccine. The DEPARTMENT justifies the incident as a human error and due to reasons of extreme urgency and necessity.

This constitutes a violation of the obligation to guarantee the confidentiality of the data, highlighting a failure to process the data in such a way that ensures adequate security of personal data, including protection against unauthorized or unlawful processing.

In light of the above and in accordance with the available evidence, it is considered that the known facts constitute an infringement attributable to the DEPARTMENT for violation of Article 5.1.f) of the GDPR.

V

Classification of the infringement of Article 5.1.f) of the GDPR

If confirmed, the aforementioned infringement of Article 5.1.f) of the GDPR could constitute the commission of the infringements classified in Article 83.5 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" states:

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 20,000,000 EUR or, in the case of an enterprise, an amount equivalent to 4% of the total annual global turnover of the previous financial year, opting for the higher amount:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

12/18

a) the basic principles for processing, including the conditions for consent pursuant to Articles 5, 6, 7, and 9; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that "Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those contrary to this organic law, constitute infringements."

For the purposes of the limitation period, Article 72 "Infringements considered very serious" of the LOPDGDD indicates:

"1. In accordance with what is established in Article 83.5 of Regulation (EU) 2016/679, the following infringements shall be considered very serious and shall be subject to a three-year limitation period:

a) The processing of personal data in violation of the principles and guarantees established in Article 5 of Regulation (EU) 2016/679. (...)"

VI

Sanction for the infringement of Article 5.1.f) of the GDPR

Without prejudice to the provisions of Article 83.5 of the GDPR, the aforementioned article provides in its paragraph 7 the following:

"7. Without prejudice to the corrective powers of the supervisory authorities under Article 58, paragraph 2, each Member State may establish rules on whether and to what extent administrative fines may be imposed on authorities and public bodies established in that Member State."

For its part, Article 77 "Regime applicable to certain categories of controllers or processors" of the LOPDGDD provides the following:

"1. The regime established in this article shall apply to the processing for which they are responsible or which they process:

c) The General Administration of the State, the Administrations of the autonomous communities, and the entities that make up the Local Administration.

2. When the controllers or processors listed in paragraph 1 commit any of the infringements referred to in Articles 72 to 74 of this organic law, the competent data protection authority shall issue a resolution

sanctioning them with a warning. The resolution shall also establish the measures that should be adopted to cease the conduct or correct the effects of the infringement that has been committed. (...)

3. Without prejudice to what is established in the previous paragraph, the data protection authority shall also propose the initiation of disciplinary proceedings when there are sufficient indications for it. In this case, the procedure and the sanctions to be applied

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

13/18

will be those established in the legislation on disciplinary or sanctioning regime that is applicable.

Likewise, when the infractions are attributable to authorities and executives, and it is evidenced that there are technical reports or recommendations for the treatment that have not been duly addressed, the resolution imposing the sanction will include a reprimand naming the responsible position and will order the publication in the corresponding Official State or regional Gazette.

5. The actions taken and the resolutions issued under this article will be communicated to the Ombudsman or, where appropriate, to the analogous institutions of the autonomous communities. (...) Therefore, with the aforementioned infraction of Article 5.1.f) of the GDPR confirmed, it is appropriate to sanction the DEPARTMENT with a WARNING.

VII

Article 32 of the GDPR

Article 32 "Security of processing" of the GDPR establishes:

"1. Taking into account the state of the art, the costs of implementation, and the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons, the controller and the processor shall implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk, which may include, among others:

- a) the pseudonymization and encryption of personal data;
- b) the ability to ensure the ongoing confidentiality, integrity, availability, and resilience of processing systems and services;
- c) the ability to restore the availability and access to personal data quickly in the event of a physical or technical incident;
- d) a process for regularly verifying, assessing, and evaluating the effectiveness of the technical and organizational measures to ensure the security of processing.

2. In assessing the appropriateness of the level of security, particular consideration shall be given to the risks presented by the processing of data, in particular as a consequence of the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data.

3. Adherence to an approved code of conduct pursuant to Article 40 or to an approved certification mechanism pursuant to Article 42 may serve as an element to demonstrate compliance with the requirements set out in paragraph 1 of this article.

4. The controller and the processor shall take measures to ensure that any person acting under the authority of the controller or the processor and having access to personal data may only process such data in accordance with the instructions of the controller."

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

14/18

instructions of the controller, unless required to do so under Union or Member State law."

Article 32 does not establish static security measures; rather, it is up to the controller to determine the necessary security measures to ensure the confidentiality, integrity, and availability of personal data.

Therefore, the same data processing may involve different security measures depending on the specific circumstances in which that data processing takes place.

In line with these provisions, Recital 75 of the GDPR states: The risks to the rights and freedoms of natural persons, of varying severity and probability, may arise from data processing that could cause physical, material, or immaterial harm, particularly in cases where the processing may lead to issues of discrimination, identity theft or fraud, financial losses, damage to reputation, loss of confidentiality of data subject to professional secrecy, unauthorized reversal of pseudonymization, or any other significant economic or social harm; in cases where data subjects are deprived of their rights and freedoms or prevented from exercising control over their personal data; in cases where the personal data processed reveal ethnic or racial origin, political opinions, religion or philosophical beliefs, trade union membership, and the processing of genetic data, data concerning health, or data concerning sexual life, or criminal convictions and related security measures; in cases where personal aspects are evaluated, in particular the analysis or prediction of aspects related to work performance, economic situation, health, preferences or personal interests, reliability or behavior, situation or movements, in order to create or use personal profiles; in cases where personal data of vulnerable individuals, particularly children, are processed; or in cases where the processing involves a large amount of personal data and affects a large number of data subjects.

Furthermore, Recital 83 of the GDPR states: In order to maintain security and prevent processing from infringing the provisions of this Regulation, the controller or processor must assess the inherent risks of the processing and apply measures to mitigate them, such as encryption. These measures must ensure an adequate level of security, including confidentiality, taking into account the state of the art and the cost of their implementation in relation to the risks and the nature of the personal data to be protected. When assessing the risk in relation to data security, the risks arising from the processing of personal data must be considered, such as the accidental or unlawful destruction, loss, or alteration of personal data transmitted, stored, or otherwise processed, or the unauthorized communication or access to such data, which may particularly cause physical, material, or immaterial harm.

Ultimately, the first step in determining security measures will be the risk assessment. Once assessed, it will be necessary to determine the security measures aimed at reducing or eliminating the risks associated with data processing.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

15/18

The principle of data security requires the application of appropriate technical or organizational measures in the processing of personal data to protect such data against access, use, modification, dissemination, loss, destruction, or accidental, unauthorized, or unlawful damage. In this regard, security measures are key to guaranteeing the fundamental right to data protection. The existence of the fundamental right to data protection is not possible if the confidentiality, integrity, and availability of this data cannot be guaranteed.

It should not be forgotten that, in accordance with Article 32.1 of the GDPR, the technical and organizational measures to be applied to ensure a level of security appropriate to the risk must take into account the state of the art, the costs of implementation, the nature, scope, context, and purposes of the processing, as well as the risks of varying probability and severity for the rights and freedoms of natural persons.

In this sense, it is important to note that the activity of the DEPARTMENT involves the processing of personal data of thousands of citizens, including health data (special category of data).

Therefore, due to the activity it engages in and the personal data it processes, it is obliged to conduct a risk analysis and implement appropriate technical and organizational measures to ensure a level of security appropriate to the risk of its activity for the rights and freedoms of individuals, taking into account especially that its activity involves processing health data.

(...)

In this regard, it is important to remember that the controller is obliged to apply appropriate and

effective measures and must be able to demonstrate compliance of the processing activities with this Regulation, including the effectiveness of the measures. Such measures must take into account the nature, scope, context, and purposes of the processing, as well as the risk to the rights and freedoms of natural persons.

(Recital 74)

Therefore, from all of the above, a lack of due diligence is deduced both in the compliance with the security measures appropriate to the risk of the processing, as well as in the supervision or verification of their observance and suitability.

In accordance with the available evidence, it is considered that the known facts constitute an infringement, attributable to the DEPARTMENT, for violation of Article 32 of the GDPR.

VIII

Classification of the infringement of Article 32 of the GDPR

If confirmed, the aforementioned infringement of Article 32 of the GDPR could constitute the commission of the infringements classified in Article 83.4 of the GDPR, which under the heading "General conditions for the imposition of administrative fines" provides:

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

16/18

"Violations of the following provisions shall be sanctioned, in accordance with paragraph 2, with administrative fines of up to 10,000,000 EUR or, in the case of an undertaking, an amount equivalent to 2% of the total global annual turnover of the previous financial year, opting for the higher amount:

a) the obligations of the controller and the processor under Articles 8, 11, 25 to 39, 42, and 43; (...)"

In this regard, the LOPDGDD, in its Article 71 "Infringements" establishes that:

"Acts and behaviors referred to in paragraphs 4, 5, and 6 of Article 83 of Regulation (EU) 2016/679, as well as those that are contrary to this organic law, constitute infringements."

For the purposes of the limitation period, Article 73 "Infringements considered serious" of the LOPDGDD indicates:

"Based on what is established in Article 83.4 of Regulation (EU) 2016/679, the following are considered serious and shall be subject to a limitation period of two years:

f) The failure to adopt those technical and organizational measures that are appropriate to ensure a level of security appropriate to the risk of the processing, in the terms required by Article 32.1 of Regulation (EU) 2016/679.

IX

Sanction for the infringement of Article 32 of the GDPR

Without prejudice to the provisions of Article 83.5 of the GDPR, the aforementioned article provides in its paragraph 7 the following:

"7. Without prejudice to the corrective powers of the supervisory authorities under Article 58, paragraph 2, each Member State may establish rules on whether and to what extent administrative fines may be imposed on authorities and public bodies established in that Member State."

For its part, Article 77 "Regime applicable to certain categories of controllers or processors" of the LOPDGDD provides the following:

"1. The regime established in this article shall apply to the processing for which they are responsible or act as processors:

a) The General Administration of the State, the Administrations of the autonomous communities, and the entities that comprise Local Administration.

2. When the controllers or processors listed in paragraph 1 commit any of the infringements referred to in Articles 72 to 74 of this organic law, the competent data protection authority shall issue

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

resolution sanctioning them with a warning. The resolution will also establish the measures that should be adopted to cease the conduct or correct the effects of the infringement that has been committed.

(...)

3. Without prejudice to what is established in the previous section, the data protection authority will also propose the initiation of disciplinary proceedings when there are sufficient indications for it. In this case, the procedure and the sanctions to be applied will be those established in the legislation on disciplinary or sanctioning regime that is applicable.

Furthermore, when the infringements are attributable to authorities and executives, and it is evidenced that there are technical reports or recommendations for the treatment that have not been duly addressed, the resolution imposing the sanction will include a reprimand naming the responsible position and will order the publication in the Official State Gazette or the corresponding regional gazette.

5. The actions taken and the resolutions issued under this article will be communicated to the Ombudsman or, where appropriate, to the analogous institutions of the autonomous communities. (...) Therefore, having confirmed the aforementioned infringement of Article 32 of the GDPR, it is appropriate to sanction the DEPARTMENT with a WARNING.

Thus, in accordance with the applicable legislation and having assessed the criteria for the graduation of the sanctions whose existence has been established,

the Director of the Spanish Agency for Data Protection RESOLVES:

FIRST: TO IMPOSE on the DEPARTMENT OF HEALTH OF THE COMMUNITY OF MADRID, GENERAL DIRECTORATE OF PUBLIC HEALTH, with NIF S7800001E, for an infringement of Article 5.1.f) of the GDPR, classified under Article 83.5 of the GDPR, a sanction of WARNING.

SECOND: TO IMPOSE on the DEPARTMENT OF HEALTH OF THE COMMUNITY OF MADRID, GENERAL DIRECTORATE OF PUBLIC HEALTH, with NIF S7800001E, for an infringement of Article 32 of the GDPR, classified under Article 83.4 of the GDPR, a sanction of WARNING.

THIRD: TO NOTIFY this resolution to the DEPARTMENT OF HEALTH OF THE COMMUNITY OF MADRID, GENERAL DIRECTORATE OF PUBLIC HEALTH, with NIF S7800001E.

FOURTH: TO COMMUNICATE this resolution to the Ombudsman, in accordance with the provisions of Article 77.5 of the LOPDGDD.

In accordance with the provisions of Article 50 of the LOPDGDD, this Resolution will be made public once it has been notified to the interested parties.

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es

Against this resolution, which concludes the administrative procedure in accordance with Article 48.6 of the LOPDGDD, and in accordance with the provisions of Article 123 of the LPACAP, the interested parties may optionally file a motion for reconsideration before the Director of the Spanish Agency for Data Protection within one month from the day following the notification of this resolution or directly file an administrative contentious appeal before the Administrative Court of the National Court, in accordance with the provisions of Article 25 and in section 5 of the fourth additional provision of Law 29/1998, of July 13, regulating the Administrative Jurisdiction, within two months from the day following the notification of this act, as provided in Article 46.1 of the aforementioned Law.

Finally, it is noted that in accordance with the provisions of Article 90.3 a) of the LPACAP, the firm resolution in the administrative procedure may be provisionally suspended if the interested party expresses their intention to file an administrative contentious appeal. If this is the case, the interested party must formally communicate this fact by means of a written document addressed to the Spanish Agency for Data Protection, submitting it through the Electronic Registry of the Agency

[<https://sedeagpd.gob.es/sede-electronica-web/>], or through any of the other registries provided for in

Article 16.4 of the aforementioned Law 39/2015, of October 1. They must also provide the Agency with documentation that proves the effective filing of the administrative contentious appeal. If the Agency does not have knowledge of the filing of the administrative contentious appeal within two months from the day following the notification of this resolution, it will consider the provisional suspension to be concluded.

938-181022

Mar España Martí

Director of the Spanish Agency for Data Protection

C/ Jorge Juan, 6

www.aepd.es

28001 – Madrid

sedeagpd.gob.es